

✎ 추가 일시	2026년 8월 21일 오후 1:58
🏠 강의	애플리케이션 보안

2026-08-21 OWASP Juice Shop 취약점 분석 실습

1. OWASP Juice Shop Easter Egg 분석

1.1 Easter Egg 파일 확인

OWASP Juice Shop에서 Easter Egg 관련 기능을 확인하는 과정에서 `easteregg` 와 관련된 Markdown 파일을 확인하였다.

파일을 열어 내용을 확인하던 중 특정 줄에 의미를 바로 파악하기 어려운 인코딩 문자열이 존재하는 것을 확인하였다.

1.2 Base64 디코딩

파일 내부에서 확인한 인코딩 문자열을 Base64 방식으로 디코딩하였다.

Base64 디코딩 이후에도 일반적인 경로 형태가 아닌 문자열이 출력되었으며, 추가적인 인코딩 또는 치환이 적용된 것으로 판단하였다.

1.3 ROT13 디코딩

Base64 디코딩 결과를 추가로 분석한 결과 ROT13 방식으로 변환된 문자열임을 확인하였다.

ROT13으로 한 번 더 디코딩한 결과 다음과 같은 경로를 확인하였다.

```
/the/devs/are/so/funny/they/hid/an/easter/egg/within/the/easter/egg
```

확인된 경로를 Juice Shop의 URL에 적용하여 접근한 결과 숨겨진 Easter Egg 페이지를 확인하였다.

1.4 분석 과정

```
인코딩된 문자열 확인
↓
Base64 Decode
↓
ROT13 Decode
↓
숨겨진 URL Path 확인
↓
URL 접근
↓
Easter Egg 페이지 확인
```

1.5 학습 내용

이번 실습을 통해 웹 애플리케이션 내부에 존재하는 문자열을 분석할 때 단순히 평문 데이터만 확인하는 것이 아니라 다양한 인코딩 및 변환 방식을 고려해야 한다는 것을 학습하였다.

특히 하나의 데이터에 여러 단계의 Encoding이 적용될 수 있으며, Base64와 ROT13을 순차적으로 분석하여 최종적인 경로를 확인할 수 있었다.

2. 로그인 기능 및 인증 방식 분석

2.1 관리자 계정 식별

Juice Shop의 상품 리뷰 기능을 확인하는 과정에서 리뷰 작성자의 계정 식별 정보를 확인할 수 있었다.

여러 리뷰 작성자 중 다음과 같은 계정을 확인하였다.

```
admin@juice-sh.op
```

해당 계정은 관리자 계정으로 추정하였으며, 로그인 기능의 인증 보안성을 점검하였다.

3. 무차별 대입 공격을 통한 관리자 계정 인증정보 확인

3.1 로그인 요청 확인

관리자 계정으로 추정되는 이메일을 입력하고 임의의 비밀번호를 입력하여 로그인을 시도하였다.

Burp Suite를 이용하여 로그인 요청을 가로채고 HTTP 요청 구조를 확인하였다.
로그인 요청은 다음과 같은 형태로 전달되는 것을 확인하였다.

```
POST /rest/user/login HTTP/1.1
```

요청 Body에는 이메일과 비밀번호가 JSON 형태로 전달되었다.

```
{
  "email": "admin@juice-sh.op",
  "password": "abcd"
}
```

이를 통해 `password` 파라미터를 대상으로 반복적인 인증 요청을 수행할 수 있음을 확인하였다.

3.2 Burp Suite Intruder 설정

Burp Suite의 **Intruder** 기능을 이용하여 로그인 요청을 자동화하였다.

공격 설정은 다음과 같다.

항목	설정
Attack Type	Sniper
Target	<code>password</code> 파라미터
Payload Type	Simple list
Payload	SecLists <code>best1050.txt</code>

Kali Linux에서 SecLists를 설치하였다.

```
sudo apt install seclists
```

설치한 SecLists에서 `best1050.txt` 를 Payload 목록으로 불러와 비밀번호 후보군으로 사용하였다.

3.3 공격 수행

Burp Suite Intruder에서 `password` 파라미터를 공격 대상으로 지정하고 준비한 비밀번호 목록을 순차적으로 대입하였다.

각 요청의 응답 코드와 응답 길이 등을 비교하여 정상적인 인증 실패 응답과 다른 결과를 확인하였다.

공격 결과 관리자 계정으로 추정되는 계정에 대해 다음 비밀번호가 확인되었다.

```
admin123
```

이를 통해 해당 로그인 기능에서 반복적인 인증 요청에 대한 충분한 보호가 적용되지 않은 것을 확인하였다.

3.4 취약점 원인

해당 로그인 기능은 공격자가 다수의 비밀번호를 자동으로 대입하는 것을 효과적으로 제한하지 못하고 있었다.

특히 다음과 같은 보안 통제가 충분하지 않은 것으로 판단하였다.

- 로그인 실패 횟수 제한
- 일정 횟수 이상 실패 시 계정 잠금
- IP 기반 요청 횟수 제한
- CAPTCHA 등의 자동화 방지 기능
- 관리자 계정에 대한 추가 인증
- 취약한 비밀번호 사용 방지 정책

또한 `admin123` 과 같이 추측하기 쉬운 비밀번호가 사용된 경우 무차별 대입 공격의 성공 가능성이 더욱 높아질 수 있다.

4. 취약점 정리

4.1 취약점명

무차별 대입 공격에 대한 인증 시도 제한 미흡

4.2 취약점 분류

인증 및 인가

4.3 공격 흐름

상품 리뷰 확인
↓
리뷰 작성자의 계정 정보 확인
↓
admin@juice-sh.op 계정 식별
↓
로그인 요청 Burp Suite로 가로채기
↓
password 파라미터 지정
↓
Burp Suite Intruder 실행
↓
SecLists best1050.txt Payload 적용
↓
비밀번호 후보 자동 대입
↓
admin123 확인
↓
관리자 계정 인증정보 획득 가능성 확인

5. 대응 방안

5.1 로그인 시도 횟수 제한

동일 계정 또는 동일 IP에서 반복적인 로그인 실패가 발생하는 경우 일정 횟수 이상부터 인증 요청을 제한해야 한다.

예를 들어 일정 횟수 이상 로그인에 실패하면 일정 시간 동안 추가 로그인을 차단하는 방식으로 무차별 대입 공격을 방어할 수 있다.

5.2 Rate Limiting 적용

짧은 시간 동안 동일 IP 또는 계정에서 과도한 로그인 요청이 발생하지 않도록 서버 측에서 요청 횟수를 제한해야 한다.

클라이언트에서만 제한할 경우 공격자가 요청을 직접 생성하여 우회할 수 있으므로 반드시 서버 측에서 적용해야 한다.

5.3 CAPTCHA 적용

반복적인 로그인 실패가 발생하는 경우 CAPTCHA를 요구하여 자동화된 공격 도구가 지속적으로 인증 요청을 수행하지 못하도록 방어해야 한다.

5.4 강력한 비밀번호 정책 적용

관리자 계정을 포함한 모든 사용자 계정에 대해 추측하기 쉬운 비밀번호의 사용을 제한해야 한다.

특히 다음과 같은 비밀번호는 사용하지 않도록 해야 한다.

```
123456  
password  
admin123  
qwerty  
111111
```

비밀번호의 길이와 복잡도를 강화하고, 알려진 취약 비밀번호 목록과 비교하여 등록을 차단하는 방법을 적용할 수 있다.

5.5 관리자 계정 MFA 적용

관리자 계정은 비밀번호만으로 인증하지 않고 OTP, 인증 앱 등의 추가 인증 수단을 적용하는 것이 바람직하다.

비밀번호가 공격자에게 노출되더라도 추가 인증을 요구함으로써 실제 관리자 계정 탈취로 이어지는 것을 방지할 수 있다.

5.6 로그인 보안 이벤트 모니터링

반복적인 로그인 실패, 비정상적인 IP에서의 접근, 짧은 시간 동안 발생하는 다수의 인증 요청 등을 로그로 기록하고 모니터링해야 한다.

이를 통해 무차별 대입 공격을 조기에 탐지하고 대응할 수 있다.

6. 오늘 실습에서 학습한 내용

6.1 웹 애플리케이션 데이터 분석

- 웹 애플리케이션 내부의 파일 및 데이터를 분석하는 방법
- Base64 Encoding/Decoding
- ROT13 Encoding/Decoding
- 다중 Encoding 데이터 분석
- 숨겨진 URL Path 및 기능 확인

6.2 Burp Suite 활용

- HTTP 로그인 요청 가로채기
- Request 구조 분석
- JSON 형태의 인증 데이터 확인
- 특정 파라미터를 대상으로 한 Intruder 공격
- Sniper Attack 활용
- Payload 설정 및 결과 비교

6.3 인증 취약점 분석

- 관리자 계정 식별 과정
- 로그인 인증 요청 분석
- 무차별 대입 공격 원리
- SecLists를 활용한 Payload 구성
- 로그인 인증 시도 제한의 중요성
- 취약한 비밀번호가 공격 성공 가능성에 미치는 영향

7. 오늘 실습 정리

이번 실습에서는 **OWASP Juice Shop**을 대상으로 웹 애플리케이션 내부의 숨겨진 데이터를 분석하고 로그인 기능의 인증 보안성을 점검하였다.

Easter Egg 분석에서는 인코딩된 문자열을 발견한 후 **Base64** → **ROT13** 순서로 디코딩하여 숨겨진 URL 경로를 확인하였다.

이후 로그인 기능을 분석하면서 상품 리뷰에 노출된 계정 식별 정보를 기반으로 관리자 계정으로 추정되는 계정을 확인하였다. Burp Suite를 이용해 로그인 요청을 분석하고 **password** 파라미터를 Intruder의 공격 대상으로 지정한 뒤 SecLists의 **best1050.txt**를 Payload로 사용하여 반복적인 인증 요청을 수행하였다.

그 결과 **admin123**이라는 비밀번호가 확인되어 **로그인 인증 시도 제한이 충분하지 않을 경우 무차별 대입 공격을 통해 관리자 계정의 인증정보가 노출될 수 있는 위험**을 확인하였다.

이번 실습을 통해 단순히 취약점을 찾는 것에서 끝나는 것이 아니라, **취약점 발견 → 공격 가능성 검증 → 원인 분석 → 보안 영향 분석 → 대응 방안 작성**까지 연결하는 웹 애플리케이션 보안 점검 과정을 경험하였다.